

Name : Bhargava S

TASK 3

Vulnerability Scan Report – Nessus (Windows Host)

1. Introduction

As part of the **Cyber Security Internship Task 3**, I performed a **basic vulnerability scan** on my Windows system using **Nessus Essentials**. The goal was to identify common vulnerabilities, understand their severity, and document potential remediation steps.

- **Tool Used:** Nessus Essentials (free edition)
- **Target:** Local Windows Host (192.168.0.105)
- **Scan Type:** Full system scan (default policies)

2. Scan Summary

- **Total Findings:** 144
- **Risk Distribution:**
 - Medium Risk: 9
 - Informational/Low/Unclassified: 135
 - High/Critical: None detected

👉 While no critical vulnerabilities were found, several medium-severity issues require attention.

Sev	CVSS	VPR	EPSS	Name	Family	Count		
MEDIUM	5.3			SMB Signing not required	Misc.	1	🔄	✎
MIXED	...	...	...	HTTP (Multiple Issues)	Web Servers	15	🔄	✎
MIXED	...	...	...	SSL (Multiple Issues)	General	13	🔄	✎
INFO	...	...	...	SMB (Multiple Issues)	Windows	6	🔄	✎
INFO	...	...	...	TLS (Multiple Issues)	Service detection	4	🔄	✎
INFO	...	...	...	TLS (Multiple Issues)	General	3	🔄	✎
INFO	...	...	...	Microsoft Windows (Multiple Issues)	Windows	2	🔄	✎
INFO				Netstat Portscanner (SSH)	Port scanners	48	🔄	✎
INFO				Service Detection	Service detection	12	🔄	✎
INFO				DCE Services Enumeration	Windows	8	🔄	✎
INFO				Unknown Service Detection: Banner Retrieval	Service detection	8	🔄	✎
INFO				Web Server No 404 Error Code Check	Web Servers	3	🔄	✎
INFO				Service Detection (HELP Request)	Service detection	2	🔄	✎
INFO				VMware ESX/GSX Server Authentication Daemon Detection	Service detection	2	🔄	✎
INFO				Additional DNS Hostnames	General	1	🔄	✎
INFO				Apache HTTP Server Version	Web Servers	1	🔄	✎
INFO				Common Platform Enumeration (CPE)	General	1	🔄	✎
INFO				Device Type	General	1	🔄	✎
INFO				Host Fully Qualified Domain Name (FQDN) Resolution	General	1	🔄	✎
INFO				Names & Cram Information	Configure	1	🔄	✎

3. Key Findings

3.1 HTTP TRACE / TRACK Methods Allowed

- **Risk Level:** Medium
- **Port:** 8080
- **Synopsis:** The remote web server allows TRACE/TRACK HTTP methods.
- **Impact:** Can be exploited for Cross-Site Tracing (XST) attacks to steal cookies or bypass controls.

Remediation: Disable TRACE/TRACK methods in the web server configuration. Example (Apache):

3.2 SSL Certificate Expired

- **Risk Level:** Medium

- **Port:** 9012
- **Synopsis:** The SSL certificate used by the server has expired.
- **Impact:** Users cannot trust the connection; attackers may impersonate the server (MITM attacks).
- **Remediation:** Replace with a valid certificate issued by a trusted Certificate Authority (CA).

3.3 SSL Certificate with Wrong Hostname

- **Risk Level:** Medium
- **Port:** 9012
- **Synopsis:** The SSL certificate's Common Name (CN) does not match the hostname.
- **Impact:** Browsers will display security warnings; attackers may intercept traffic.
- **Remediation:** Issue a certificate with the correct hostname (matching the system's IP or domain).

4. Informational Findings

Several non-exploitable but useful informational results were noted:

- Service Detection (HTTP, SMB, SSL, WebSocket++)
- Operating System Identification
- NetBIOS / SMB Host Information Disclosure

5. Risk Assessment

- **Overall Security Posture:** Moderate
- No high-risk vulnerabilities detected.

- Medium-risk SSL and HTTP misconfigurations could be exploited if not addressed.

6. Recommendations

1. Disable insecure HTTP methods (TRACE/TRACK).
2. Update and replace expired SSL certificates.
3. Reissue SSL certificates with correct hostnames.
4. Perform monthly vulnerability scans.
5. Keep Windows OS and software updated with the latest security patches.

7. Conclusion

This vulnerability scan demonstrated practical use of **Nessus Essentials** for detecting misconfigurations and weaknesses. While no critical vulnerabilities were found, addressing the **medium-risk SSL and HTTP issues** will significantly improve the host's overall security.